

VULNERABILITY ASSESSMENT REPORT

Task 3 — Cybersecurity & Ethical Hacking

Maincrafts Technology Internship Program

Date: June 2, 2026 | Target: 192.168.56.101 | Classification: CONFIDENTIAL

Analyst	Madhav Mishra
Assessment Type	Vulnerability Assessment (Non-Exploitative)
Target System	OWASP Juice Shop on 192.168.56.101:3000
Lab Environment	Kali Linux (Attacker) + Oracle VirtualBox
Tools Used	Nmap 7.99, Nikto v2.6.0
Scope	Network 192.168.56.0/24 — Lab systems only
Assessment Date	June 2, 2026
Report Status	FINAL — Task 3 Submission

1. Executive Summary

This Vulnerability Assessment Report (VAR) documents the findings of a structured security assessment conducted against an intentionally vulnerable lab environment as part of Maincrafts Technology's Cybersecurity & Ethical Hacking Internship (Task 3). The assessment was strictly non-exploitative — vulnerabilities were identified and documented, not exploited.

The target system (192.168.56.101) was found to be running OWASP Juice Shop, a deliberately insecure web application, on port 3000. Network reconnaissance confirmed three active hosts within the 192.168.56.0/24 subnet. While Nmap's full TCP service scan returned all ports as filtered (likely due to firewall rules), the Nikto web scanner identified a significant number of security issues at the application layer.

Key findings at a glance:

CRITICAL	HIGH	MEDIUM	LOW / INFO
2	3	4	4

2. Methodology & Scope

2.1 Rules of Engagement

- Assessment limited to lab systems on the 192.168.56.0/24 subnet
- No exploitation of vulnerabilities — identification and documentation only
- No Denial-of-Service (DoS) or destructive actions
- All scans performed from Kali Linux attacker VM within VirtualBox

2.2 Tools & Commands Used

Tool	Command	Purpose
Nmap 7.99	nmap -sn 192.168.56.0/24 -oN host-discovery.txt	Host discovery — identify live hosts
Nmap 7.99	nmap --privileged -sV -Pn -oN full-service-text.txt 192.168.56.101	Service version enumeration on target
Nikto v2.6.0	nikto -h http://192.168.56.101:3000 -o nikto.txt	Web application vulnerability scanning

3. Network Reconnaissance Results

3.1 Host Discovery (nmap -sn)

Command: nmap -sn 192.168.56.0/24 — Completed in 1.96 seconds, 256 addresses scanned.

IP Address	MAC Address	Notes
192.168.56.1	0A:00:27:00:00:0D	VirtualBox Host-Only adapter gateway (Unknown vendor)
192.168.56.100	08:00:27:B0:8F:AE	Oracle VirtualBox virtual NIC — DHCP server
192.168.56.101	—	TARGET — Juice Shop / vulnerable web app host

3.2 Port & Service Scan (nmap -sV -Pn)

The full TCP service scan against 192.168.56.101 returned all 1000 scanned ports in a filtered state (no-response). This indicates a firewall or packet filtering is dropping probe packets on the standard port range. However, Nikto successfully connected to port 3000, confirming the web service is active. A targeted scan of port 3000 is recommended.

Note: Scan duration was 201.77 seconds — consistent with filtered ports timing out.

4. Technical Findings

VULN-01 — Sensitive Files Exposed via Web Root

Severity	CRITICAL (CVSS: 9.1)
Description	The web server exposes highly sensitive files accessible via direct GET requests. These include .htpasswd (authorization credentials), .bash_history, .sh_history (shell command history with potential credentials), and userdata.json, PasswordsData.json, login.json, master.json, connections.json, accounts.json (potential database/credential dumps). These were all identified by Nikto.
Evidence	<i>Nikto output lines 14-27: GET /.htpasswd — Contains authorization information; GET /.bash_history, /.sh_history — Shell history retrieved; GET /userdata.json, /PasswordsData.json, /login.json, /connections.json, /accounts.json — Flagged as interesting.</i>
Impact	An attacker could retrieve plaintext or hashed credentials, database connection strings, internal commands run on the server, and user account data. This could lead directly to complete system compromise.
Remediation	Immediately remove all sensitive files from the web root. Configure the web server (e.g., Nginx/Express) to deny access to files matching *.json credential patterns, *.history, and .htpasswd. Implement strict allowlist-based routing.

VULN-02 — JAMon Admin Interface Exposed (CVE-2013-6235)

Severity	CRITICAL (CVSS: 8.8)
Description	A JAMon (Java Application Monitor) Admin interface was detected at /JAMonAdmin.jsp. JAMon versions 2.7 and earlier are vulnerable to Cross-Site Scripting (XSS) as documented in CVE-2013-6235. Admin monitoring interfaces should never be publicly accessible.

Evidence	<i>Nikto output line 28: GET /JAMonAdmin.jsp — JAMon Admin interface identified. Versions 2.7 and earlier contain XSS vulnerabilities. See CVE-2013-6235.</i>
Impact	Exposed admin interfaces allow attackers to monitor application performance metrics, potentially inject malicious scripts (XSS), and gather information about the backend infrastructure. In combination with other vulnerabilities, this could enable session hijacking.
Remediation	Restrict access to /JAMonAdmin.jsp via IP allowlisting or move behind authentication. Update JAMon to a version beyond 2.7. If JAMon is not required, remove it from the deployment.

VULN-03 — CORS Misconfiguration — Wildcard Origin

Severity	HIGH (CVSS: 7.5)
Description	The server returns an Access-Control-Allow-Origin: * header on all responses. This means any website on the internet can make cross-origin requests to this server and read the responses, bypassing the Same-Origin Policy.
Evidence	<i>Nikto output line 5: GET /: Retrieved access-control-allow-origin header: *</i>
Impact	Malicious websites can make authenticated API calls on behalf of logged-in users, steal sensitive data returned from API endpoints, and conduct CSRF-like attacks more effectively. This is especially dangerous given the exposed JSON endpoints.
Remediation	Replace the wildcard with a specific allowlist of trusted origins. Example in Express.js: <code>cors({ origin: 'https://trustedsite.com' })</code> . Never use * in production environments handling sensitive data.

VULN-04 — Missing HTTP Security Headers (Multiple)

Severity	HIGH (CVSS: 6.5)
Description	The web application is missing four critical HTTP security headers: Referrer-Policy, Permissions-Policy, Strict-Transport-Security (HSTS), and Content-Security-Policy (CSP). These headers form a baseline defense against common web attacks.
Evidence	<i>Nikto output lines 8-11: Missing headers: referrer-policy, permissions-policy, strict-transport-security, content-security-policy.</i>
Impact	Without CSP, XSS attacks can execute freely. Without HSTS, users can be downgraded to HTTP and intercepted (MITM). Without Referrer-Policy, sensitive URL parameters leak to third parties. Without Permissions-Policy, unauthorized access to device APIs (camera, mic) may be possible.
Remediation	Add the following response headers in the server configuration: Content-Security-Policy (restrict script sources), Strict-Transport-Security: max-age=31536000; includeSubDomains, Referrer-Policy: no-referrer-when-downgrade, Permissions-Policy: geolocation=(), microphone=().

VULN-05 — Missing X-Content-Type-Options Header

Severity	HIGH (CVSS: 5.3)
Description	The X-Content-Type-Options header is absent. This header prevents browsers from MIME-sniffing a response away from the declared Content-Type, which can allow attackers to trick browsers into executing malicious content.
Evidence	<i>Nikto output line 29: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion than the MIME type declared.</i>
Impact	Attackers can upload files with misleading extensions that get executed as different content types (e.g., a .txt file executed as JavaScript). This amplifies the risk of file upload vulnerabilities.
Remediation	Add the response header: X-Content-Type-Options: nosniff to all HTTP responses.

VULN-06 — robots.txt Discloses Internal Paths

Severity	MEDIUM (CVSS: 4.3)
Description	The /robots.txt file is present and contains at least one entry. While robots.txt is used to control web crawler behavior, listing sensitive or internal paths in it actually advertises those paths to attackers who read the file.
Evidence	<i>Nikto output line 7: GET /robots.txt: contains 1 entry which should be manually reviewed.</i>
Impact	Any paths listed in robots.txt become a roadmap for attackers. Disallowed paths often include admin panels, internal APIs, or staging environments.
Remediation	Review the contents of robots.txt. Do not list sensitive internal paths. Instead, protect those paths with authentication and authorization controls.

VULN-07 — Unconventional Header Discloses Recruiting Info

Severity	LOW (CVSS: 2.0)
Description	The server returns a non-standard HTTP header x-recruiting with the value /#/jobs. While this is likely a recruitment easter egg (common at tech companies), it unnecessarily reveals information about the application framework and discloses an internal path.
Evidence	<i>Nikto output line 6: GET /: Uncommon header(s) 'x-recruiting' found, with contents: /#/jobs.</i>
Impact	Low direct risk. However, information leakage from custom headers can assist attackers in fingerprinting the application and its developers. May hint at additional hidden paths.
Remediation	Remove non-standard headers from production responses. Custom headers should follow the X- prefix convention and only be used intentionally with awareness of the information they expose.

VULN-08 — Potentially Sensitive Public Directories

Severity	MEDIUM (CVSS: 5.0)
Description	The /ftp/ and /public/ directories were flagged as accessible. Publicly accessible directories can contain unintended files, backups, or test data if directory listing is enabled or files are inadvertently placed there.
Evidence	<i>Nikto output lines 12-13: GET /ftp/: This might be interesting; GET /public/: This might be interesting.</i>
Impact	If directory listing is enabled, attackers can enumerate all files in these directories and download sensitive data such as backup files, configuration files, or uploaded user content.
Remediation	Disable directory listing on the web server. Ensure /ftp/ and /public/ do not contain sensitive files. Apply appropriate access controls. For /ftp/ specifically, consider whether FTP exposure via HTTP is intended.

5. Risk Summary Table

ID	Vulnerability	Severity	CVSS	Remediation Summary
VULN-01	Sensitive Files in Web Root	CRITICAL	9.1	Remove files, restrict routing
VULN-02	JAMon Admin XSS (CVE-2013-6235)	CRITICAL	8.8	Restrict access, update JAMon
VULN-03	CORS Wildcard Misconfiguration	HIGH	7.5	Restrict CORS origins
VULN-04	Missing Security Headers (4)	HIGH	6.5	Add CSP, HSTS, Referrer, Permissions
VULN-05	Missing X-Content-Type-Options	HIGH	5.3	Add nosniff header
VULN-06	robots.txt Path Disclosure	MEDIUM	4.3	Audit robots.txt contents
VULN-07	x-recruiting Header Leakage	LOW	2.0	Remove custom headers
VULN-08	Public Directory Exposure	MEDIUM	5.0	Disable directory listing

6. Impact Analysis

The combination of vulnerabilities identified creates a compounding risk profile:

- The exposed sensitive JSON files (VULN-01) combined with CORS misconfiguration (VULN-03) create a scenario where an attacker on any website could silently read credential and user data via a cross-origin request.
- The JAMon admin interface (VULN-02) with known XSS vulnerability provides a direct avenue for session hijacking and administrative access.
- The absence of Content-Security-Policy (VULN-04) means that any XSS payload, once injected, faces no browser-level containment — scripts can freely exfiltrate data.
- Exposed shell history files (.bash_history, .sh_history) may contain previously executed commands including passwords, API keys, or internal hostnames that assist lateral movement.

7. Assessment Gaps & Recommendations

The following steps from the Task 3 checklist were not completed or produced partial results:

Gap	Reason	Recommended Action
Dirsearch scan (Step 4)	No dirsearch output provided	Run: dirsearch -u http://192.168.56.101:3000 -o ~/lab/scans/dirsearch.txt

Nmap on port 3000	Full scan showed all ports filtered; port 3000 not specifically targeted	Run: nmap -sV -p 3000 192.168.56.101 to confirm open port
OpenVAS/Nessus (optional)	Not performed	Optional but strongly recommended for enterprise-grade assessment

8. Conclusion

This vulnerability assessment successfully identified 8 security issues of varying severity on the target system 192.168.56.101 (OWASP Juice Shop). The most critical findings — exposed credential files and a known XSS-vulnerable admin interface — represent immediate remediation priorities in a real-world environment.

The assessment demonstrates a solid understanding of the vulnerability identification workflow using industry-standard tools (Nmap, Nikto). The next phase (Task 4) will involve active exploitation of the identified vulnerabilities to validate their real-world impact.

All testing was conducted ethically, within the defined lab scope, with no exploitation or destructive actions performed.

Analyst Madhav Cybersecurity Intern, Maincrafts Technology	Assessment Details Date: June 2, 2026 Target: 192.168.56.101:3000 Classification: CONFIDENTIAL — Lab Use Only
--	---